

AI 기반 KCMVP 사전 검증 시스템: 규칙 탐지와 LLM 의미론적 분석의 하이브리드 모델

조수빈* 박도윤* 임다은* 김재환* 정수민* 형유림* 서화정*

한성대학교 (학부생, 교수*)

AI-based KCMVP Pre-certification System: A Hybrid Model of Rule-based Detection and LLM Semantic Analysis

Su-Been Cho*, Do-Yun Park*, Da-Eun Lim*, Jae-Hwan Kim*, Su-Min Jeong*, Yu-Lim Hyong*, Hwa-Jeong Seo*

Hansung University (Undergraduate student, Professor*)

요약

KCMVP 인증은 긴 검증 시간과 반복적인 보완으로 인한 비용 및 일정 지연이 주요 한계점이다. 이를 보완하기 위해 본 논문은 KCMVP 인증 전 미리 오답을 감지하기 위한 3단계 퍼널형 AI 사전 검증 프레임워크를 제안한다. 1단계(L1)는 KCMVP 기반으로 설계된 YAML 규칙을 통해 결정론적으로 위반 후보를 탐지하고, 2단계(L2)는 RAG 기반 검색으로 KCMVP 가이드라인 근거를 매핑하며, 3단계(L3)는 LLM을 활용해 코드와 근거 맥락을 종합하여 최종 판정을 수행하여 오답률을 줄인다. 초기 평가 결과, 테스트 183건의 위반에 대해 82.0%의 탐지율을 달성하였으며, L3(LLM)가 L1 오답 53건 중 94.3%를 정확히 제거하여 퍼널 구조에 의한 단계적 정제 효과를 확인하였다.

I. 서론

한국 암호모듈 검증 제도(KCMVP [1])의 인증 프로세스는 장기간이 소요된다. 특히 심사 과정에서 발생하는 반복적인 보완 요청은 심각한 비용 가중과 일정 지연의 주요 원인이 되고 있다. 그럼에도 공식 제출 전에 KCMVP 요구사항 준수 여부를 미리 점검할 수 있는 자동화 도구는 현재 부재한 실정이다. 이에 본 연구는 규칙 기반 정적 탐지(L1), RAG 기반 가이드라인 근거 검색(L2), LLM 기반 최종 판정(L3)을 결합한 퍼널형 하이브리드 사전 검증 프레임워크를 제안하여, 검증 과정의 병목을 해소하고자 한다. 본 논문에서는 소프트웨어 암호 모듈, 그 중에서도 LEA [2]를 대상으로 진행하였다.

1.1 주요 기여

- **하이브리드 3단계 파이프라인:** 규칙 기반 탐지(L1), RAG 근거 검색(L2), LLM 판정(L3)의 퍼널형 결합으로 검증 정밀도를 높인다.

- **검증 규칙셋 체계화:** KCMVP 요구사항 (보안, 알고리즘 등)을 YAML로 구조화하여 대규모 규칙을 효율적으로 관리한다.

- **코드·문서 통합 검증:** 소스코드와 각종 제출 문서를 동시에 검증할 수 있도록 한다.

II. 배경

국가정보원(NIS)과 한국인터넷진흥원(KISA)이 주관하는 KCMVP는 정부 및 공공기관 정보 시스템에 도입되는 암호모듈에 대한 필수 법정 인증 제도이다. KS X ISO/IEC 19790 [3]을 기반으로 하며, 검증 신청, 서면 및 기술 검토(본 심사), 최종 심의의 4단계로 구성된다 [1]. 이 전체 인증 프로세스는 통상 1년 6개월가량 소요된다고 알려져 있다. 또한 반복적인 보완 요청으로 인해 수 주에서 수개월의 추가 지연이 발생할 수 있다.

III. 시스템 설계

본 시스템은 규칙 기반 결정론적 탐지(L1),

RAG 기반 가이드라인 근거 검색(L2), LLM 기반 최종 판정(L3)의 세 단계를 퍼널형으로 구성하여 오탐을 순차적으로 축소한다. 그림 1은 전체 파이프라인을 도식화한 것이다.

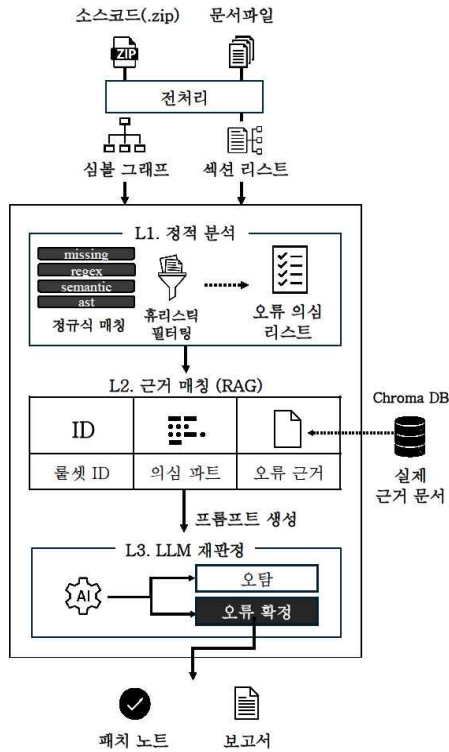


그림 1. 전체 파이프라인 구성도

초반 소스코드(ZIP)와 제출 문서(PDF)를 동시에 입력받아 전처리한다. 코드 측에서는 pycparser를 활용한 AST 파싱으로 함수 정의·호출 정보를 추출하고, 문서 측에서는 PDF에서 본문·표를 추출한 뒤 섹션 단위로 구조화하여 분석을 진행한다.

3.1 L1: 규칙 기반 정적 분석

L1은 KCMVP 기반[4,5]의 YAML로 설계된 점검 규칙을 네 가지 패턴 유형으로 적용하여 위반 후보 집합을 생성한다. 규칙은 공통 보안(COM), LEA 특화(LEA), 운영 모드별(CBC/CTR/GCM 등), 문서(DOC), 추적성(TRC)의 다섯 범주로 분류된다.

이때 패턴 유형은 4가지로 나뉜다. *missing* 유형은 필수 패턴의 부재를 의미하며, 이 자체가 위반이므로 L3를 거치지 않는다. *regex*는 위반 패턴 탐지로, 정규표현식 매칭 후, 도메인

특화 휴리스틱으로 오탐을 사전 필터링한다. *semantic*과 *ast*는 각각 키워드·문맥 단서와 구문 구조를 매칭하며, 맥락적 재해석이 필요하므로 L3 재판정을 우선 수행한다.

3.2 L2: RAG 기반 근거 매칭

L2에서는 직접적인 판정은 진행되지 않고, L1에서 식별된 위반 후보에 KCMVP 가이드라인 근거를 부착하여 L3 판정을 위한 맥락을 구성하여 프롬프트를 전달하는 역할을 한다. 위반 위치 주변의 코드·문서 구간을 발췌하여 토큰 예산 내에서 맥락을 보존한다.

근거 검색은 3계층 구조로 설계되었다: (1) 규칙 식별자와 가이드라인 조항의 직접 매핑을 최우선 적용하고, (2) ChromaDB 벡터 검색으로 의미적으로 유사한 근거를 보장하며, (3) 벡터 검색이 유효하지 않을 경우 TF-IDF 키워드 폴백으로 어휘적 유사도 기반의 근거를 확보한다. 수집된 근거는 코드 슬라이스·위반 설명과 함께 프롬프트로 구성되어 L3에 전달된다.

3.3 L3: LLM 기반 의미론적 재판정

L3는 Gemini 2.5 Flash Lite [6]를 활용하여 L1 위반 후보에 대해 코드·근거 맥락을 읽고 오탐 여부를 최종 판정한다. 패턴 유형별로 판정 지침과 신뢰도 하한이 다르게 설계되며, 1차 응답의 신뢰도가 낮거나 증거 맥락이 불충분한 경우 플래그를 통해 보수적으로 후속 검토로 넘긴다. 최종 출력은 JSON 구조로 is real issue(위반여부), confidence(신뢰도), description(판정 근거), suggestion(수정 권고)을 포함한다.

3.4 추적성 검증

추적성 검증(TRC)은 코드의 공개 함수 선언·에러 상수와 설계서·시험서의 언급을 3방향으로 대조한다 - 설계서 대 헤더(API 명세 누락), 설계서 대 소스(에러 코드 불일치), 시험서 대 헤더(공개 함수 시험 커버리지)를 기계적으로 점검하여 코드-문서 간 일관성을 검증한다.

그림 2는 제안하는 퍼널형 아키텍처를 적용하여, 사용자가 단계별 검증 결과를 직관적으로 파악할 수 있도록 구현한 프로토타입 구동화면이다*.

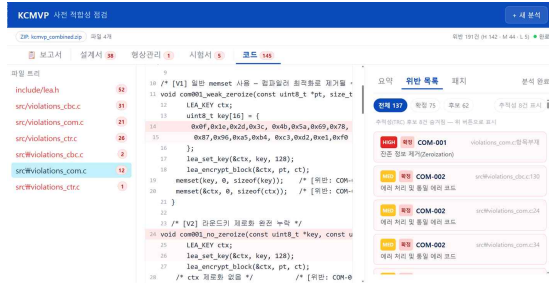


그림 2 웹 프로토타입 메인 화면 및 패널 구조

IV. 평가

LEA 알고리즘의 C 언어 구현체와 보안 정책서를 기반으로 의도적인 위반 사항을 주입한 데이터 파일을 구성하여 평가를 진행하였다. 표 1은 파이프라인 각 단계의 성능을 나타낸다.

표 1: 코드 위반 탐지 성능 (4세트 합산, GT 183건).

지표	결과
True Positive (TP)	150건
False Negative (FN)	33건
탐지율 (Recall)	82.0%
GT 외 추가 탐지 건	97건
L3 필터링 - 제거 건수	53건(36.6%)
L3 필터링 - 정확 제거율	94.3%(50/53)
L3 필터링 - 오판 (FN 유발)	3건(5.7%)
문서 구조 누락 탐지	평균 38.5건/세트
패치 성공률	89.5%(17/19)

반복적인 테스트에서 다음과 같은 경향이 관찰되었다. 첫째, L1은 missing 유형에서 사실상 완전한 가까운 재현율을 보였다. 둘째, L3는 semantic 계열에서 단순 키워드 적중만으로 생기던 오탐을 효과적으로 줄였으나, 코드 내 연산 순서를 검증하는 부분에서 일부 오판이 발생하였다. 셋째, AST 전용 검사기가 갖춰진 규칙은 정규식 폴백 대비 복잡한 코드에서 오탐이 적었다. 넷째, 제출 문서에서 필수 섹션·형식의 구조적 누락을 발견하는 정확도가 높았다.

그러나 본 시스템은 두 가지 주요 한계를 지닌다. 첫째, 텍스트 레이아웃이 없는 스캔 PDF나 이미지 기반 PDF의 경우 본문 추출이 어려워 문서 규칙 검증이 사실상 불가능하다. 둘째, 테스트 데이터 위주의 평가는 실제 KCMVP 데이터의 규모와 다양성을 모두 대표하지 못하며, 인증 기관과의 협력을 통한 실데이터 검증이

* 전체 흐름은 유튜브에서 확인할 수 있다.

<https://www.youtube.com/watch?v=IrtS4wZZKgU>

장기적으로 필요하다.

V. 결론

본 논문은 정적 분석(L1), RAG 기반 근거 매핑(L2), LLM 기반 최종 판정(L3)을 결합한 퍼널형 KCMVP 사전 검증 프레임워크를 구현하여, 각 단계가 상보적으로 오탐을 줄이고 해석 가능성을 높이는 실효성을 확인하였다. 향후 연구로는 한계점을 해결하기 위해 AST 분석 고도화를 통한 정규식 의존도 축소, 산학 협력을 통한 실제 제출물 기반 유효성 검증, 그리고 지원 암호 알고리즘 확대를 추진할 계획이다.

VI. Acknowledgment

This work was supported by Institute of Information & communications Technology Planning & Evaluation (IITP) grant funded by the Korea government(MSIT) (No.RS-2025-02306395, Development and Demonstration of PQC-Based Joint Certificate PKI Technology, 40%) and this work was supported by the Institute of Information & Communications Technology Planning & Evaluation(IITP) grant funded by the Korea government(MSIT) (No. RS-2025-25394739, Development of Security Enhancement Technology for Industrial Control Systems Based on S/HBOM Supply Chain Protection, 40%) and this work was supported by the IITP(Institute of Information & Communications Technology Planning & Evaluation)-ITRC(Information Technology Research Center) grant funded by the Korea government(Ministry of Science and ICT)(IITP-2026-RS-2020-II201797, 20%).

[참고문헌]

- [1] 국가정보원 (National Intelligence Service), 암호모듈 시험 및 검증지침 (guidelines for cryptographic module testing and validation), 국가정보원 지침 (제정 2021. 11. 1, 개정 2025.6. 1), 2025. In

Korean.

- [2] D.Hong, J.-K.Lee, D.-C.Kim, D.Kwon, K.H.Ryu and D.-G.Lee, Lea: A 128-bit block cipher for fast encryption on common processors, WISA 2013, vol. 8267 of Lecture Notes in Computer Science, Springer, 2014.
- [3] 국가기술표준원 (Korean Agency for Technology and Standards), KS X ISO/IEC 19790:2015 - information technology - security techniques - security requirements for cryptographic modules, 2015. Korean adoption of ISO/IEC 19790:2012.
- [4] 국가정보원(NIS), 국가보안기술연구소 (NSR), 암호모듈 구현안내서 (Guide for Vendor Implementations) Part 2: 검증대상 암호알고리즘 구현안내서, 2024.
- [5] 한국인터넷진흥원(KISA), 암호모듈 제출물 작성 안내서, 2025.
- [6] Google, We're expanding our Gemini 2.5 family of models, Google Blog, 2025.